



AuthGuard

Adaptive Multi-Factor Authentication and Single Sign-On Gateway

Secure Software Engineering

Summer 2025–2026

Supervisor: Dr. Saleem Alsaraireh

Student Name	ID
Alia Ahmad Aladwan	232445
Mohammad Ali Ismail	231134
Mohammad Fayez AlQudah	235860

Contents

Contents	2
1. Executive Summary	4
2. Project Description	4
2.1 What is it?	4
2.2 Who is it for?	4
2.3 Main Goal	4
2.4 Scope and Assumptions.....	4
3. Security Requirements	6
3.1 Inputs to Requirements Gathering.....	6
3.2 Authentication and Access Control (AUTH).....	6
3.3 Data Protection (DATA)	7
3.4 Input Validation (INPUT).....	8
3.5 Audit and Logging (AUDIT)	9
3.6 API and Session Security (API)	9
3.7 Infrastructure and Configuration (INFRA)	9
3.8 Compliance (COMP)	10
3.9 Priority Classification	10
3.10 Acceptance Criteria	10
4. Security Use Cases	11
4.1 UC-1: Authenticate to AuthGuard	11
4.2 UC-2: Register and Prove Identity Ownership.....	12
4.3 UC-3: Carry a Verified Identity Across Portals (SSO)	13
4.4 UC-4: Enroll or Change a Second Factor.....	14
4.5 UC-5: Recover a Forgotten Password Securely	15
4.6 UC-6: Recover from an Account Lockout	16
4.7 UC-7: Terminate the Session Everywhere	17
4.8 UC-8: Block a Compromised Account and Review the Trail	18
5. Threat Modeling and Misuse Cases.....	20
5.1 MC-1: Brute-force / Credential Stuffing	20
5.2 MC-2: Broken SSO Trust Boundary.....	21
5.3 MC-3: Automated Bot Signup.....	22
5.4 MC-4: Session Left Open on a Shared Computer	23
5.5 MC-5: Phishing of the Shared Login Domain	24
5.6 Traceability Matrix.....	25

6. STRIDE Threat Analysis	27
7. System Workflow	28
7.1 Registration Workflow.....	28
7.2 Login Workflow.....	28
7.3 SSO and Logout Workflow	29
8. Conclusion	29
References	30

1. Executive Summary

AuthGuard is a secure identity and access gateway that protects the login boundary of a multi-portal university system against modern credential-based cyber threats. By combining Auth0-based Single Sign-On (SSO), Multi-Factor Authentication (MFA), and a layered attack-protection stack, the system ensures that a student's identity remains verified, portable across services, and resistant to automated and credential-based attacks.

2. Project Description

2.1 What is it?

AuthGuard is the identity and access layer of a university web platform composed of four integrated portals — a Main portal, Course Registration, Exams, and Events, each served on its own origin. It protects the shared login boundary using Auth0's hosted identity service, layered attack protection, and multi-factor authentication, so that a single verified identity governs access across all four portals.

The central security property of the design is credential isolation: the four portal applications never receive, process, or store a password. Authentication happens only on Auth0's hosted Universal Login page and each portal receives nothing but a signed token proving who the user is. As a result, compromising one portal cannot yield a single credential.

A student may sign in with an email address or a username, or federate through Google. All four origins are registered as Allowed Callback URLs, Allowed Logout URLs and Allowed Web Origins, so the identity provider refuses to issue a token to any other address.

2.2 Who is it for?

- University students who need access to multiple academic services (course registration, exam schedules, campus events).
- System administrators who manage identities, roles, and access policy across the portals.
- Security auditors who need a verifiable record of authentication events and account lockouts.

2.3 Main Goal

To let a student authenticate once and securely move between all university portals without re-entering credentials, while ensuring the login process itself resists brute-force attacks, credential stuffing, automated bots, and breached-password reuse.

2.4 Scope and Assumptions

Aspect	Detail
In scope	Authentication, MFA, session and SSO trust boundary, attack protection, password policy, email verification and reset, audit logging of identity events
Out of scope	The internal business logic of the four portals, database design for academic records, and network/server hardening of the portal hosts
Identity provider	Auth0 (hosted Universal Login), one tenant and one Application shared by all four portals

Aspect	Detail
Login identifiers	Email address or username (5-15 characters); Google (google-oauth2) as a federated option with automatic account linking on a matching email
Second factors	One-time password from an authenticator app, and WebAuthn with FIDO device biometrics; the user is prompted to choose a factor to enrol
Client type	React single-page applications — public clients, therefore PKCE is mandatory and no client secret exists
Environment	Local development; all four portal origins are registered on localhost ports 3000 to 3003
Key assumption	Auth0 correctly implements the platform-level controls it advertises: bcrypt password hashing, encryption at rest, and RS256 token signing

3. Security Requirements

Security requirements are gathered in the first phase of the development life cycle, alongside functional requirements, and are derived from industry standards, applicable regulation, and a history of past vulnerabilities. They are grouped here into the seven standard categories used in the course requirements-gathering method.

3.1 Inputs to Requirements Gathering

Input Document	Content	What it Contributed
Business requirement	Provide students with one secure login across four university portals	The SSO and session requirements
Threat modeling session	Misuse cases MC-1 to MC-5 (Section 5)	Attack protection, MFA, trust-boundary and logout requirements
STRIDE analysis	Section 6	Systematic coverage of all six threat categories
Standards	NIST SP 800-63B, OWASP ASVS and Authentication Cheat Sheet, RFC 6749 / 7636 / 7519	Password, token, session and validation requirements
Compliance	GDPR-style data-protection principles for student personal data	The data minimization requirement
Past vulnerabilities	Known OAuth/OIDC failure modes: implicit-flow token leakage, alg:none, open redirect	AUTH-010, API-002, INPUT-002

3.2 Authentication and Access Control (AUTH)

ID	Requirement	Verification	Priority
AUTH-001	The system shall require multi-factor authentication (OTP or WebAuthn) for all user logins.	Attempt login with a correct password only; expect access denied	P0
AUTH-002	Passwords shall be at least 8 characters and satisfy at least 3 of the 4 character types (uppercase, lowercase, digit, special), with three or more sequential characters (ABC, 123) and three or more identical characters (AAA, 000) blocked.	Attempt 'passwordd', 'Abc12345' and 'Aaa!1111'; expect each rejected by the corresponding rule	P1
AUTH-003	An account shall be blocked after 10 consecutive failed login attempts regardless of the source IP address, and the owner shall be notified by email.	Submit 10 wrong passwords from varying addresses; confirm the block and the notification email	P1

ID	Requirement	Verification	Priority
AUTH-004	Authentication traffic shall be throttled per IP address: at most 5 failed logins (renewing at 50/day), 3 signups (20/day) and 10 token exchanges (144/day).	Script a burst from one address; confirm throttling engages at the configured threshold	P1
AUTH-005	Email ownership shall be proven by a verification link, which sets the email_verified flag on the profile after account creation.	Register, then confirm the profile stays unverified until the link is opened	P0
AUTH-006	Both email and username shall be usable as login identifiers, and the username shall be 5 to 15 characters and required on every profile.	Attempt usernames of 4 and 16 characters; log in with each identifier	P2
AUTH-007	Password reset shall be possible only through the branded Auth0 reset email; no alternative fallback channel shall exist.	Search the portals for any other reset mechanism; expect none	P1
AUTH-008	Google (google-oauth2) shall be accepted as a federated login, and a Google identity presenting an email that matches an existing account shall be linked to that account rather than creating a duplicate.	Sign in with Google using a registered email; confirm one profile results	P2
AUTH-009	Refresh tokens shall expire after 300 seconds of inactivity and after 43,200 seconds (about 12 hours) absolutely, forcing re-authentication on abandoned sessions.	Leave a session idle past 300 s; expect re-authentication	P1
AUTH-010	Authentication shall use Auth0 Universal Login with the Authorization Code Flow and PKCE; the portals shall never receive credentials.	Capture network traffic during login; confirm no password reaches the portal origin	P0
AUTH-011	A logout action shall terminate the shared Auth0 session so that no portal remains authenticated.	Log in to all four portals, log out of one, reload the others	P1

3.3 Data Protection (DATA)

ID	Requirement	Verification	Priority
DATA-001	Passwords shall be stored only as salted one-way hashes and never in a recoverable form.	Inspect the user store; confirm no reversible password field	P0
DATA-002	All traffic to the identity provider, and all system mail, shall use TLS 1.2 or higher — credentials never cross the network in the clear.	TLS scan of the Auth0 endpoints and the SMTP relay; confirm version and cipher suite	P0

ID	Requirement	Verification	Priority
DATA-003	Tokens shall be signed with RS256, and the signing private key shall never leave the identity provider.	Confirm no portal configuration contains a signing key or client secret	P0
DATA-004	No secret shall be stored in front-end source code or in the repository; the SPAs are public clients using PKCE.	Run secret scanning over the repository	P0
DATA-005	User personal data shall be encrypted at rest in the identity store.	Review the platform storage-encryption statement	P1
DATA-006	Secrets shall never appear in logs, URLs, or browser storage.	Review sample log entries and request URLs	P1
DATA-007	System mail shall be sent through the project's own SMTP relay (smtp.gmail.com, port 465, implicit SSL/TLS, LOGIN authentication), and the stored SMTP credentials shall be encrypted at rest.	Send a test message; confirm the port, the TLS handshake and the From address	P1

3.4 Input Validation (INPUT)

ID	Requirement	Verification	Priority
INPUT-001	All user input shall be validated server-side against allow lists before processing.	Submit malformed and oversized values to each field	P1
INPUT-002	Callback, logout and web-origin URLs shall be strictly allow-listed; any unregistered redirect_uri shall be rejected.	Send an /authorize request with an unregistered redirect_uri	P0
INPUT-003	The state and nonce parameters shall be generated per request and validated on return.	Replay a callback with a mismatched state; expect abort	P1
INPUT-004	Authentication error messages shall be generic and shall not reveal whether an account exists.	Compare responses for a valid and an invalid username	P2
INPUT-005	reCAPTCHA v2 shall be enforced with the Always setting on database-connection login, on signup, and on password reset.	Attempt a scripted signup and a scripted reset; expect the challenge to block both	P1
INPUT-006	Output shall be contextually encoded in all four portals to prevent cross-site scripting.	Inject a script payload into a profile field and render it	P1

3.5 Audit and Logging (AUDIT)

ID	Requirement	Verification	Priority
AUDIT-001	All authentication events shall be logged with a timestamp, user ID, source IP address, and outcome.	Perform a successful and a failed login; confirm both entries	P1
AUDIT-002	Attack-protection events — lockouts, breached-password rejections and bot blocks — shall be logged.	Trigger each event and confirm the corresponding entry	P1
AUDIT-003	Security events shall notify the user or administrator immediately: breached-credential use, account blocks, and high-velocity traffic throttling all raise mail, with notification frequency set to Immediately.	Trigger a lockout and a breached-password attempt; confirm both mails arrive	P1
AUDIT-004	Logs shall never contain passwords, one-time codes, or complete tokens.	Review sample log records for secret material	P1

3.6 API and Session Security (API)

ID	Requirement	Verification	Priority
API-001	Every protected API request shall require a valid access token.	Call a protected endpoint with no token; expect 401	P0
API-002	Tokens shall be validated on every request for signature, issuer, audience and expiry, with the algorithm pinned to RS256.	Submit a token with alg set to none; expect rejection	P0
API-003	The ID token lifetime shall be 900 seconds (15 minutes), so that an intercepted token has limited value.	Decode a token and confirm the exp claim; replay it after expiry	P1
API-004	CORS policy shall permit only the four registered portal origins (localhost:3000-3003).	Issue a cross-origin request from an unregistered origin	P1

3.7 Infrastructure and Configuration (INFRA)

ID	Requirement	Verification	Priority
INFRA-001	All four client applications shall authenticate against one identical Auth0 tenant and Application (same domain and Client ID), preserving a single trusted SSO session boundary.	Compare the domain and Client ID in all four portal configurations	P0

3.8 Compliance (COMP)

ID	Requirement	Verification	Priority
COMP-001	Only the personal data necessary for authentication shall be collected: an email address, a username, and a credential. No national ID, phone number or address is stored.	Review the fields captured at signup	P2

3.9 Priority Classification

Priority	Meaning	Requirements
P0 — Critical	Direct compromise of credentials or of the trust boundary if absent	AUTH-001, AUTH-005, AUTH-010, DATA-001, DATA-002, DATA-003, DATA-004, INPUT-002, API-001, API-002, INFRA-001
P1 — High	Substantially raises the risk of account takeover or abuse if absent	AUTH-002, AUTH-003, AUTH-004, AUTH-007, AUTH-009, AUTH-011, DATA-005, DATA-006, DATA-007, INPUT-001, INPUT-003, INPUT-005, INPUT-006, AUDIT-001, AUDIT-002, AUDIT-003, AUDIT-004, API-003, API-004
P2 — Medium	Hardening and usability of the security controls	AUTH-006, AUTH-008, INPUT-004, COMP-001

3.10 Acceptance Criteria

- I. Each requirement must be testable and measurable — every entry states a verification method producing a pass or fail result.
- II. Security controls must not obstruct legitimate users; where a control can lock a user out, a recovery path exists (AUTH-003 with AUTH-007).
- III. Every requirement listed is one the team has implemented and can demonstrate; the verification column is the test that shows it working.
- IV. Every requirement must trace to an identified threat — the matrix in Section 5.6 shows that no misuse case is left unmitigated.

4. Security Use Cases

Because the scope of AuthGuard is the login and authentication block, every use case in this section is a security use case: each one exists to establish, prove, protect, or terminate an identity. They are therefore described not only by their main flow but by their security-relevant alternate flows — the paths taken when a check fails — because those failure paths are where the security behaviour of the system is actually visible.

Each use case names the controls it exercises and the misuse case that threatens it. Section 5 inverts these into attacks, and the controls named here are the numbered requirements of Section 3.

ID	Security Use Case	Actor	Primary Security Property
UC-1	Authenticate to AuthGuard	Authorized User	Authentication
UC-2	Register and prove identity ownership	New User	Authentication, Availability
UC-3	Carry a verified identity across portals (SSO)	Authorized User	Authentication, Authorization
UC-4	Enrol or change a second factor	Authorized User	Authentication
UC-5	Recover a forgotten password securely	Authorized User	Authentication, Availability
UC-6	Recover from an account lockout	Authorized User	Availability
UC-7	Terminate the session everywhere (logout)	Authorized User	Confidentiality
UC-8	Block a compromised account and review the trail	Administrator	Authorization, Non-repudiation

4.1 UC-1: Authenticate to AuthGuard

Actor	Authorized User (student or administrator)
Security Goal	Prove identity with two factors of different types before any session is issued
Precondition	The account exists, the email is verified, and a second factor is enrolled
Main Flow	1. User is redirected to Auth0 Universal Login. 2. Email or username and password are submitted on the Auth0 domain, never on the portal — or the user signs in with Google instead. 3. reCAPTCHA and attack protection evaluate the attempt. 4. The password is verified against the stored hash. 5. The second factor is requested and verified. 6. Tokens are issued and the shared session cookie is created. 7. The event is logged.
Alternate Flow A	Wrong password: a generic failure message is returned that does not reveal whether the account exists; the attempt is counted and logged.

Alternate Flow B	Tenth consecutive failure: the account is blocked and the legitimate owner is emailed a warning (continues in UC-6). Separately, a single IP address is throttled after 5 failed logins.
Alternate Flow C	The password is found in a breach database: authentication is blocked and the user is directed to reset it.
Security Controls	MFA (AUTH-001) · breach screening (AUTH-002) · account block (AUTH-003) · per-IP throttling (AUTH-004) · federated login and linking (AUTH-008) · PKCE and hosted login (AUTH-010) · generic errors (INPUT-004) · audit logging (AUDIT-001)
Postcondition	A verified session exists and is attributable to a specific identity in the log
Threatened by	MC-1 (Brute-force / Credential Stuffing), MC-5 (Phishing of the login page)

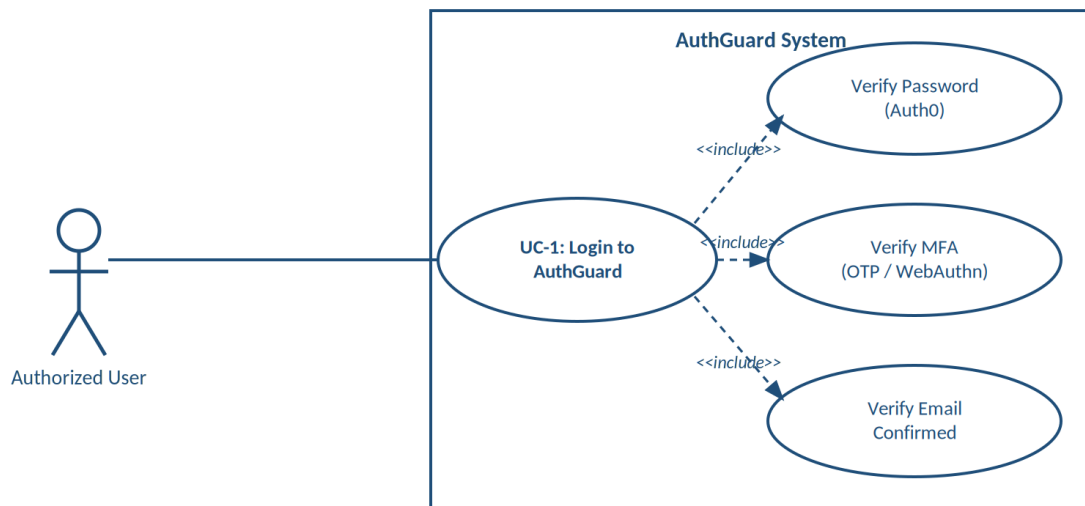


Figure 1: Authenticate to AuthGuard (UC-1)

4.2 UC-2: Register and Prove Identity Ownership

Actor	New User
Security Goal	Create an account only for a human who demonstrably controls the email address supplied, and only with a credential that is not already compromised
Precondition	The user has no existing account and controls the mailbox supplied
Main Flow	1. User submits email, username (5-15 characters) and password. 2. The password policy is enforced. 3. reCAPTCHA v2 confirms a human is present. 4. Breach screening checks the credential. 5. The account is created, the password stored only as a salted hash. 6. A verification email is sent from the project SMTP relay and opened, setting email_verified. 7. A second factor is enrolled (UC-4).
Alternate Flow A	Password fails the policy or appears in a breach list: registration is refused and the reason is shown without revealing the screening data.
Alternate Flow B	reCAPTCHA fails: the request is rejected before an account or an email is created, which protects both the directory and the email quota.

Security Controls	Password policy (AUTH-002) · breach screening (INTG-005 equivalent, AUTH-002) · reCAPTCHA v2 (INPUT-005) · username rules (AUTH-006) · email verification (AUTH-005) · salted hashing (DATA-001) · signup throttling (AUTH-004)
Postcondition	A verified account exists whose owner has proven mailbox control and holds a second factor
Threatened by	MC-3 (Automated Bot Signup)

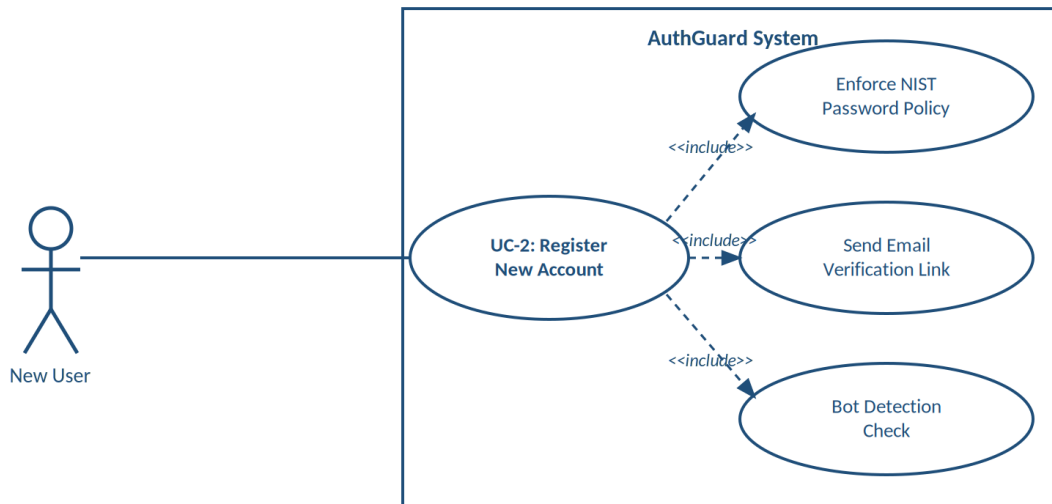


Figure 2: Register and prove identity ownership (UC-2)

4.3 UC-3: Carry a Verified Identity Across Portals (SSO)

Actor	Authorized User
Security Goal	Reuse one proven identity across all four portals without weakening it, and without any portal ever handling a credential
Precondition	An active Auth0 session exists from UC-1
Main Flow	1. User opens a second portal. 2. The portal redirects to /authorize with its own state and nonce. 3. Auth0 finds the existing session cookie on its own domain. 4. New tokens are issued silently for that portal's audience. 5. The portal independently validates the signature, issuer, audience and expiry before trusting any claim.
Alternate Flow A	The portal is registered against a different tenant or Client ID: the session is not recognised, the user is forced to authenticate separately, and that login falls outside the central MFA policy and audit log. This is the failure MC-2 describes.
Alternate Flow B	The token fails validation: access is refused with 401 and the event is logged.
Security Controls	Single tenant and Client ID (INFRA-001) · token validation with pinned algorithm (API-002) · state and nonce per request (INPUT-003) · short token lifetime (API-003)
Postcondition	The user is authenticated on the second portal under exactly the same identity and policy as the first

Threatened by	MC-2 (Broken SSO Trust Boundary), MC-4 (Session left open on a shared computer)
---------------	---

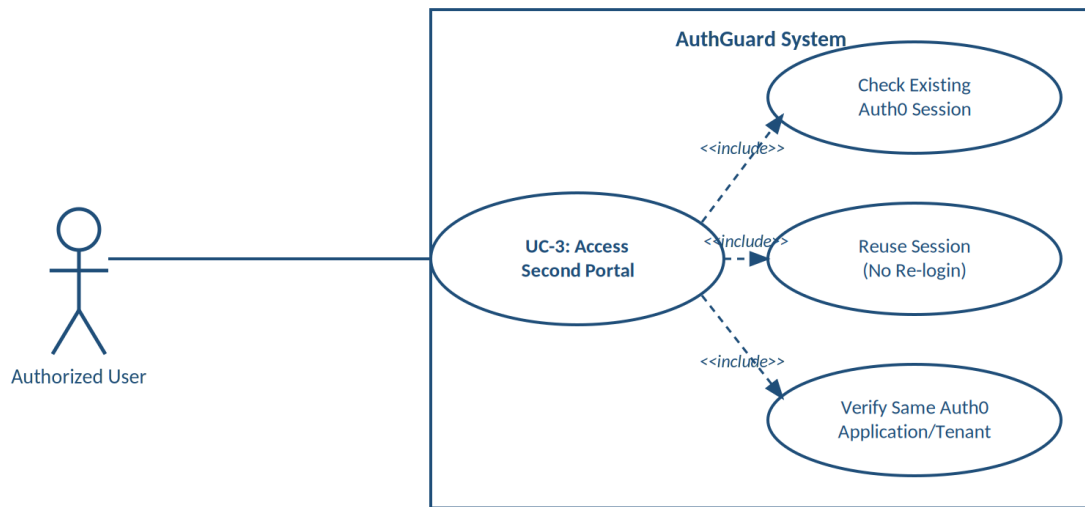


Figure 3: Carry a verified identity across portals (UC-3)

4.4 UC-4: Enroll or Change a Second Factor

Actor	Authorized User
Security Goal	Bind a possession or biometric factor to the account, so that a stolen password alone can never authenticate
Precondition	The user is authenticated and the email address is verified
Main Flow	1. The user chooses a factor. 2. For OTP, a secret is shown as a QR code and scanned into an authenticator app, then a generated code is returned to prove it works. 3. For WebAuthn, the device generates a key pair and only the public key is registered. 4. The factor becomes active and the enrolment is logged.
Alternate Flow A	The confirmation code is wrong: enrolment does not complete, so an unusable factor can never be attached to an account.
Alternate Flow B	A second factor is added or replaced later: the operation requires an already-authenticated session and is written to the audit log, so factor changes are attributable.
Security Controls	MFA enrolment (AUTH-001) · authenticated session required · enrolment and change events logged (AUDIT-001)
Postcondition	The account holds at least one working second factor
Threatened by	MC-1 and MC-5 — this use case is the control that defeats both once a password is compromised

UC-4: Enrol or Change a Second Factor

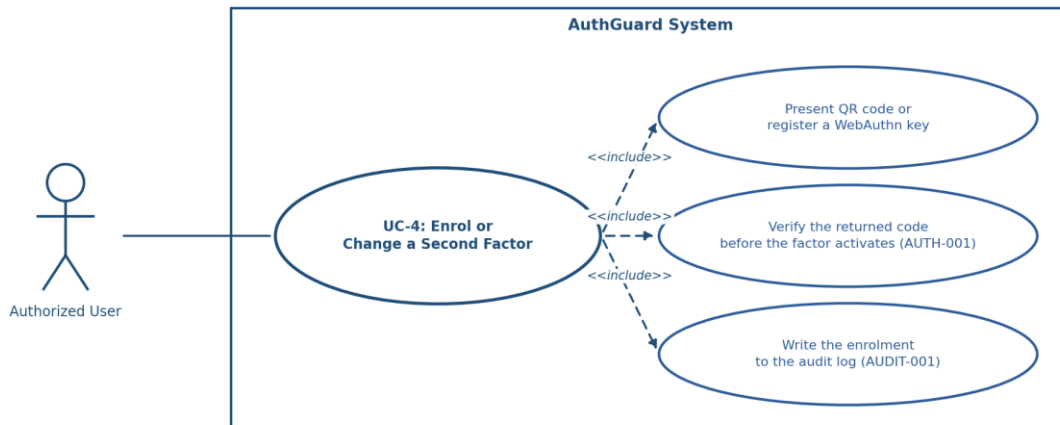


Figure 4: Enrol or change a second factor (UC-4)

4.5 UC-5: Recover a Forgotten Password Securely

Actor	Authorized User
Security Goal	Restore access through the mailbox the user already proved they own, without creating a weaker parallel authentication path
Precondition	The account exists and the user controls the registered mailbox
Main Flow	1. The user requests a reset. 2. Auth0 sends the branded reset email — the only supported channel. 3. The user opens the time-limited link. 4. The new password is validated against the policy and the breach database. 5. The password is replaced and the event is logged.
Alternate Flow A	The email address is not registered: the same confirmation message is shown either way, so the reset form cannot be used to discover which accounts exist.
Alternate Flow B	The new password appears in a breach list or fails the policy: the reset is refused, preventing recovery from being used to install a weak credential.
Security Controls	Single trusted reset channel (AUTH-007) · policy and breach screening on the new password (AUTH-002) · generic responses (INPUT-004) · logging (AUDIT-001)
Postcondition	The password is changed; no alternative or weaker reset channel exists anywhere in the system
Threatened by	MC-1 (attackers targeting the reset endpoint)

UC-5: Recover a Forgotten Password Securely

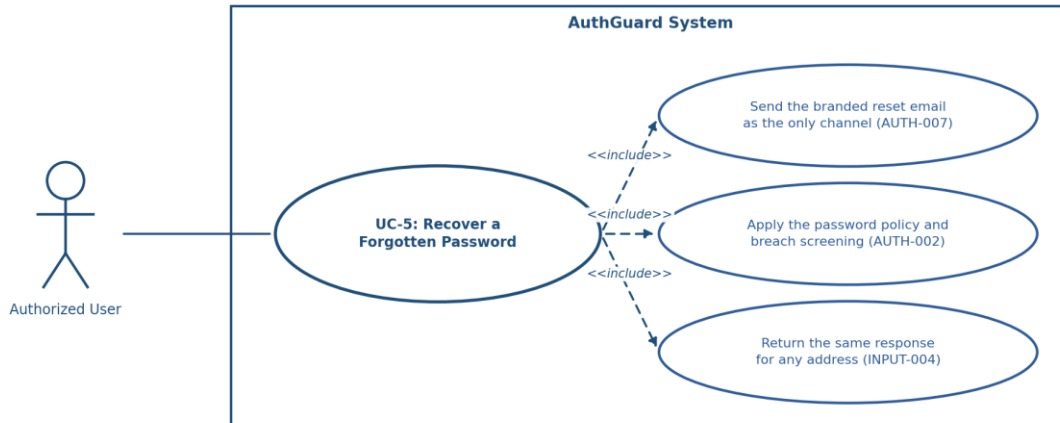


Figure 5: Recover a forgotten password securely (UC-5)

4.6 UC-6: Recover from an Account Lockout

Actor	Authorized User whose account has been locked by attack protection
Security Goal	Return a legitimate owner to service after a brute-force attempt, without giving the attacker the same route back in
Precondition	The account was blocked after ten consecutive failed attempts
Main Flow	1. The owner receives the blocked-account email, which also serves as a warning that the account is under attack. 2. The owner resets the password through UC-5, or an administrator unblocks the account. 3. Authentication is attempted again and succeeds with password plus second factor. 4. The recovery is logged.
Alternate Flow A	The attacker attempts the same recovery: they do not control the mailbox, so the reset link never reaches them, and they do not hold the second factor.
Alternate Flow B	Repeated lockouts occur: this is treated as an ongoing attack and is escalated to the administrator (UC-8).
Security Controls	Account block after 10 failures (AUTH-003) · per-IP throttling (AUTH-004) · notification to the owner (AUDIT-003) · mailbox-bound recovery (AUTH-007) · MFA still required after recovery (AUTH-001)
Postcondition	The legitimate owner has access; the attacker has gained nothing from having caused the lockout
Threatened by	MC-1 — note that the lockout itself can be abused as a denial of service against a specific student, which is why this recovery path is a requirement and not an optional convenience

UC-6: Recover from an Account Lockout

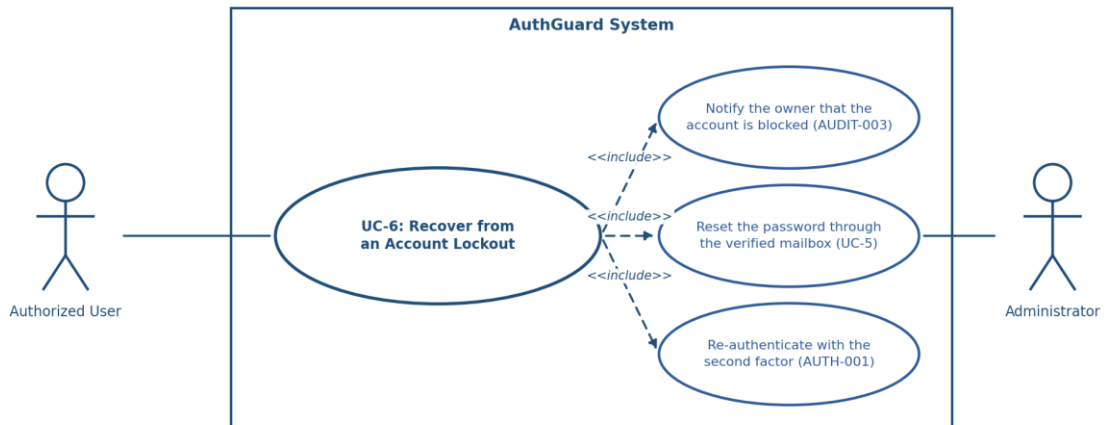


Figure 6: Recover from an account lockout (UC-6)

4.7 UC-7: Terminate the Session Everywhere

Actor	Authorized User
Security Goal	Guarantee that ending a session in one place ends it in all four portals, which matters most on shared laboratory machines
Precondition	The user is authenticated with an active shared session
Main Flow	1. The user clicks Log out on any portal. 2. The portal calls the Auth0 logout endpoint. 3. The shared session cookie is destroyed at the identity provider. 4. The user is redirected to an address on the allowed logout list. 5. The logout is logged.
Alternate Flow A	The user closes the browser without logging out: the idle timeout terminates the session automatically, which is the control that limits the damage of MC-4.
Alternate Flow B	The redirect target is not on the allowed logout list: the redirect is refused, so the logout endpoint cannot be abused as an open redirect to a phishing page.
Security Controls	Shared-session logout (AUTH-011) · 300 s idle and 43,200 s absolute limits (AUTH-009) · allow-listed logout URLs (INPUT-002) · logging (AUDIT-001)
Postcondition	No portal remains authenticated for that identity
Threatened by	MC-4 (Session Left Open on a Shared Computer)

UC-7: Terminate the Session Everywhere

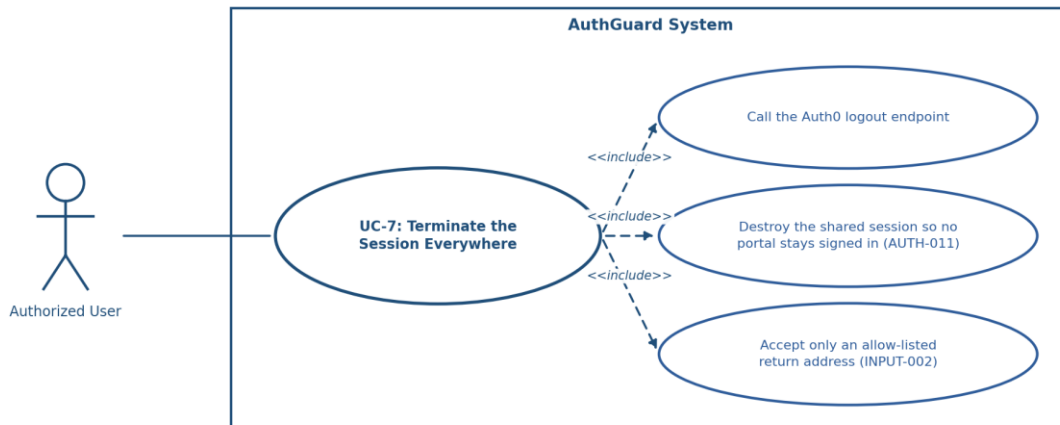


Figure 7: Terminate the session everywhere (UC-7)

4.8 UC-8: Block a Compromised Account and Review the Trail

Actor	Administrator
Security Goal	Contain a suspected compromise quickly, and be able to reconstruct afterwards what happened and to whom it is attributable
Precondition	The administrator holds the administrator role, and an alert or report indicates suspicious activity
Main Flow	1. The administrator reviews the account's authentication log: timestamps, source addresses, outcomes, lockouts. 2. The account is blocked. 3. A password reset is forced (UC-5), and the second factor reset if it may be under the attacker's control. 4. Every administrative action is itself logged with the administrator's identity.
Alternate Flow A	A non-administrator attempts the same operation: the request is refused, because administrative capability is granted by role rather than by knowing the URL.
Alternate Flow B	The user later disputes an action taken on the account: the log shows which identity performed it, from which address, at which time, and with which factor.
Security Controls	Role-based administrative access (AUTH-009) · immutable audit trail (AUDIT-001, AUDIT-003) · alerting (AUDIT-003) · no secrets in logs (AUDIT-004)
Postcondition	The account is contained and every step of the response is attributable
Threatened by	MC-2 — an authentication path outside the trusted tenant would never appear in this log, which is why INFRA-001 is a prerequisite for this use case to be meaningful

UC-8: Block a Compromised Account and Review the Trail

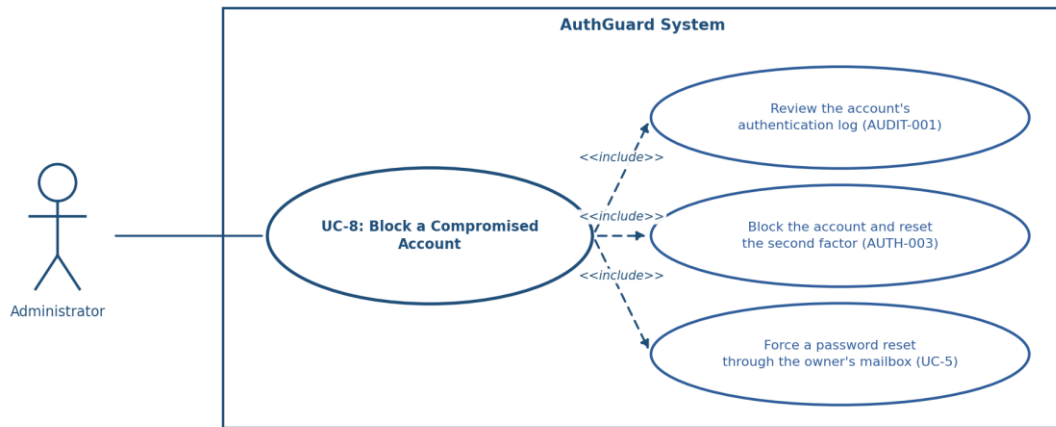


Figure 8: Block a compromised account and review the trail (UC-8)

5. Threat Modeling and Misuse Cases

To build a resilient identity layer, AuthGuard's design considers both the intended login and registration operations and the ways they could be abused by external attackers, bots, or configuration mistakes.

ID	Category	Misuse Case
MC-1	External attack	Brute-force / Credential Stuffing
MC-2	Configuration / Insider	Broken SSO Trust Boundary
MC-3	External attack	Automated Bot Signup
MC-4	Opportunistic insider	Session Left Open on a Shared Computer
MC-5	External attack	Phishing of the Shared Login Domain

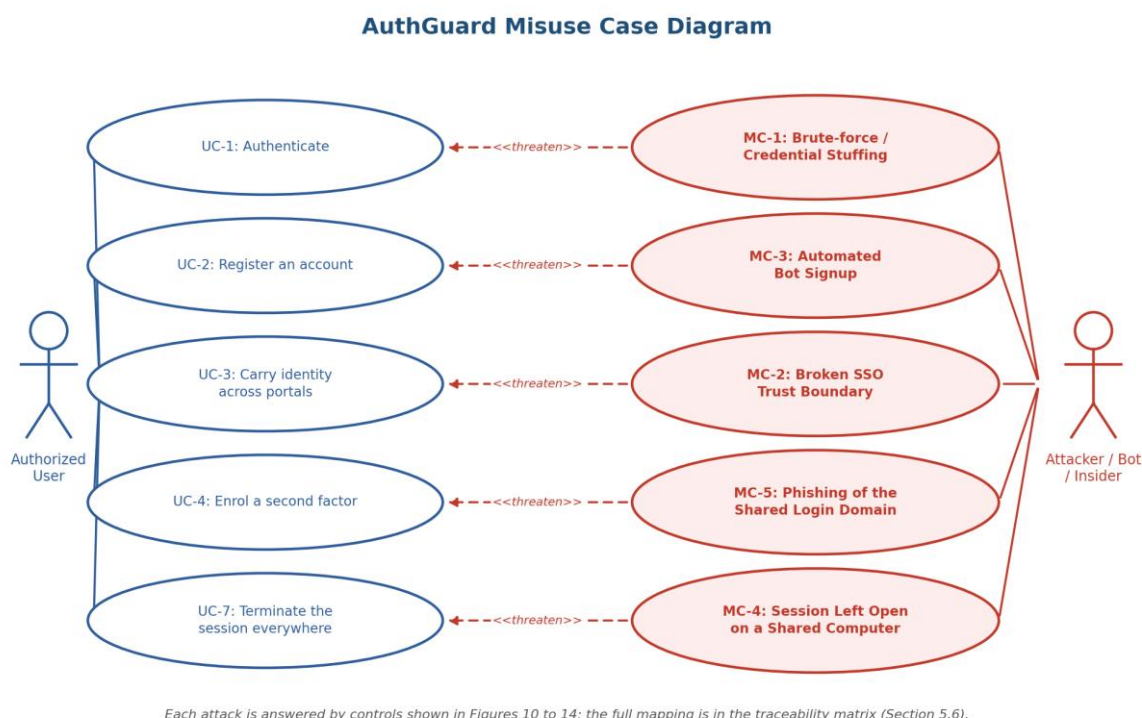


Figure 9: Misuse case overview — which use case each attack threatens

5.1 MC-1: Brute-force / Credential Stuffing

Attacker	External attacker or automated script
Description	An attacker repeatedly submits password guesses, or reuses leaked credential lists, against the login endpoint to hijack a student account.
Attack Steps	1. Attacker collects or guesses valid usernames. 2. Automated tooling submits credential pairs at high rate. 3. A weak or reused password eventually matches and the attacker authenticates as the victim.
Impact	Account takeover and unauthorized access to academic data

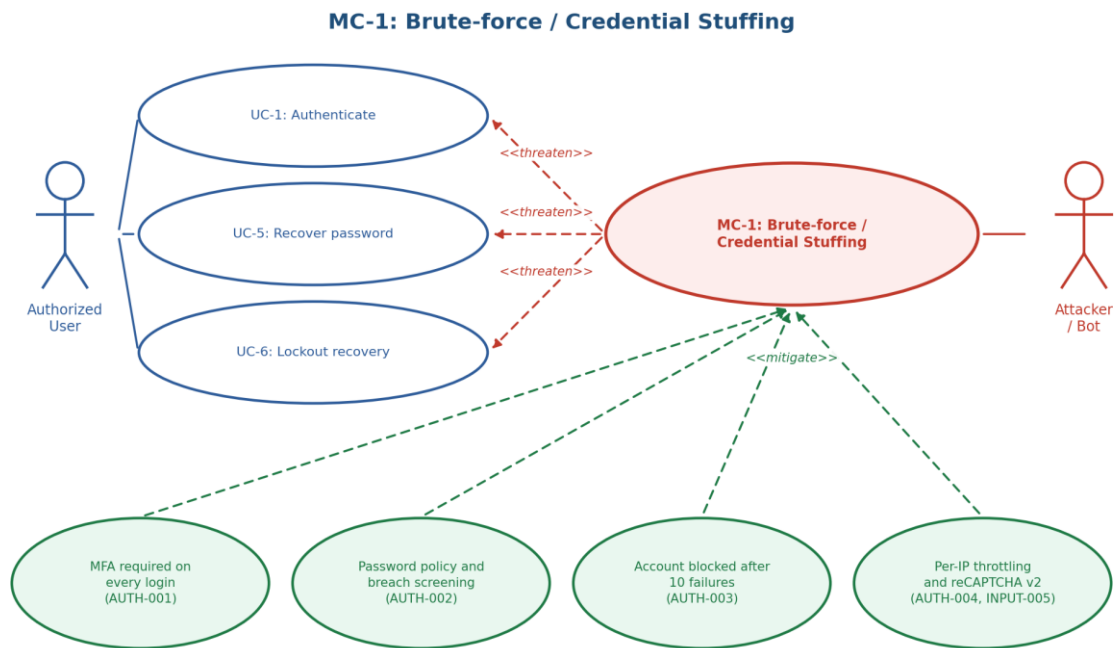


Figure 10: MC-1 brute-force / credential stuffing, and the controls that answer it

5.2 MC-2: Broken SSO Trust Boundary

Attacker	Configuration error, or an insider deliberately mis-registering a portal
Description	A portal is configured against a different Auth0 tenant or Application than the trusted one, breaking the single-session guarantee and leaving an unmonitored identity boundary.
Attack Steps	1. A portal is registered with a different domain or Client ID. 2. Its users authenticate outside the trusted tenant, so MFA policy and attack protection no longer apply. 3. Those logins never appear in the central audit log.
Impact	Unmonitored authentication path and policy bypass across the trust boundary

MC-2: Broken SSO Trust Boundary

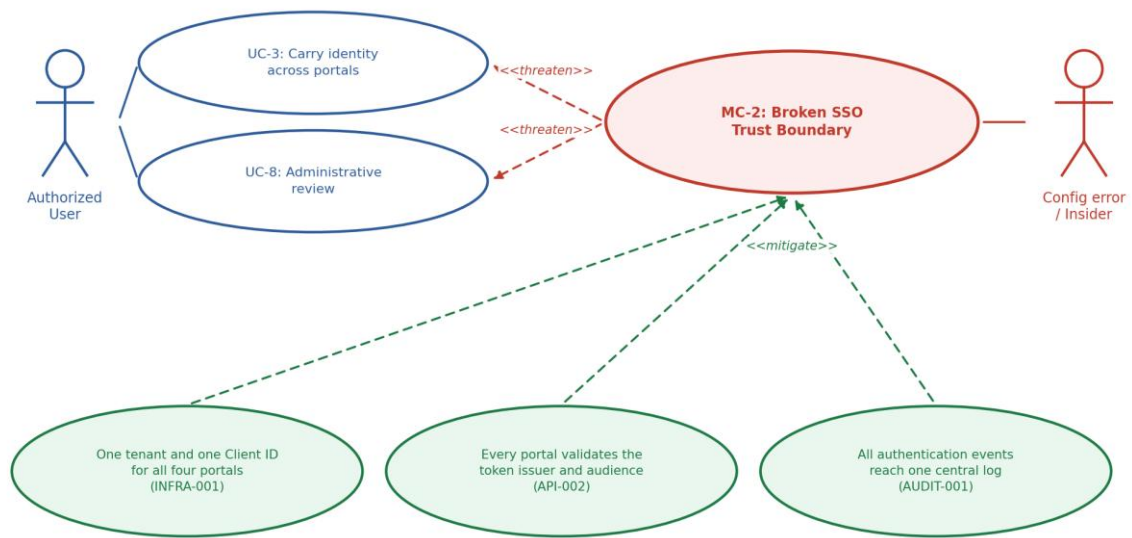


Figure 11: MC-2 broken SSO trust boundary, and the controls that answer it

5.3 MC-3: Automated Bot Signup

Attacker	External attacker running an automated script
Description	A script mass-creates fake accounts or probes the registration endpoint, bypassing the human-driven signup flow.
Attack Steps	1. Attacker scripts the registration form. 2. The endpoint accepts requests without human verification. 3. Fake accounts are mass-created, polluting the directory and consuming the email quota.
Impact	Denial of service, cost abuse through verification emails, and an untrustworthy directory

MC-3: Automated Bot Signup

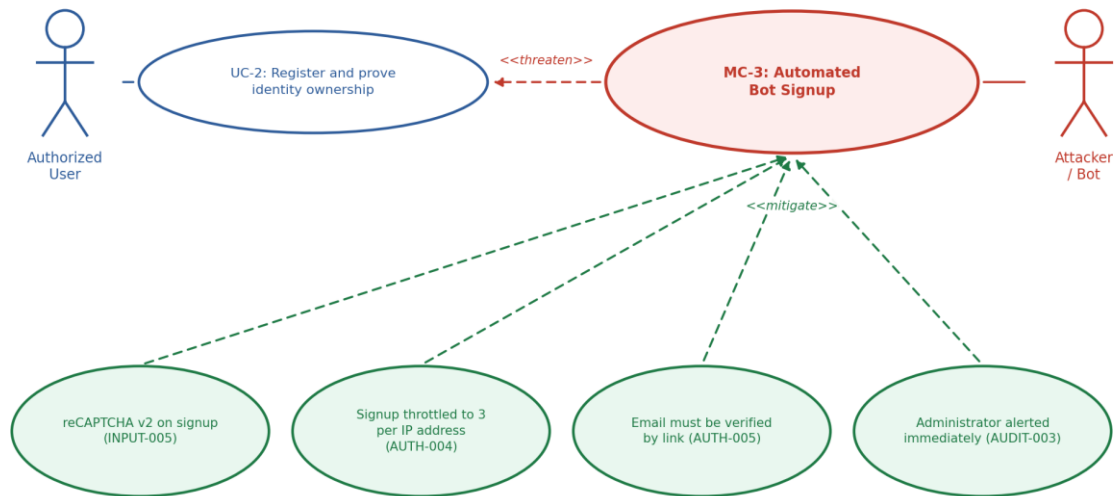


Figure 12: MC-3 automated bot signup, and the controls that answer it

5.4 MC-4: Session Left Open on a Shared Computer

Attacker	Opportunistic insider — the next person to use the same laboratory machine
Description	A student authenticates in a shared lab and leaves without logging out. Because SSO is active, the next user inherits a live session across all four portals.
Attack Steps	1. Victim logs in and walks away. 2. Attacker uses the same browser and opens any portal. 3. The shared session grants access with no prompt.
Impact	Confidentiality breach, and failure of non-repudiation — the log attributes the attacker's actions to the victim

MC-4: Session Left Open on a Shared Computer

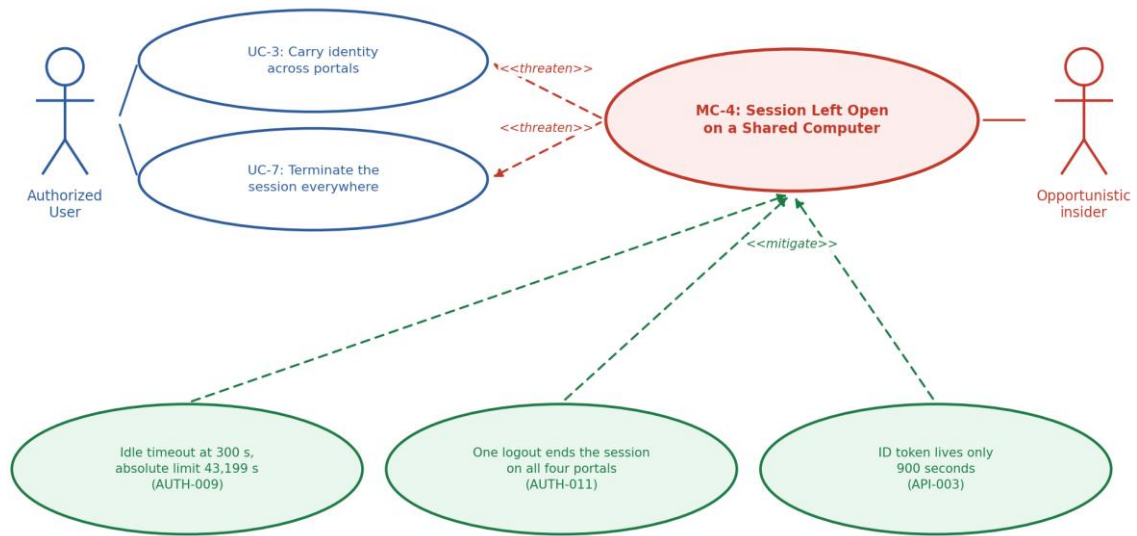


Figure 13: MC-4 session left open on a shared computer, and the controls that answer it

5.5 MC-5: Phishing of the Shared Login Domain

Attacker	External attacker running a credential-harvesting page
Description	The login page is served from a shared provider domain rather than a university-owned one, so students are less able to recognise a convincing fake.
Attack Steps	1. Attacker clones the Universal Login page. 2. A link is emailed to students. 3. The real and fake domains are hard to tell apart. 4. Credentials are captured.
Impact	Credential theft — though MFA limits the damage, since the password alone is not sufficient

MC-5: Phishing of the Shared Login Domain

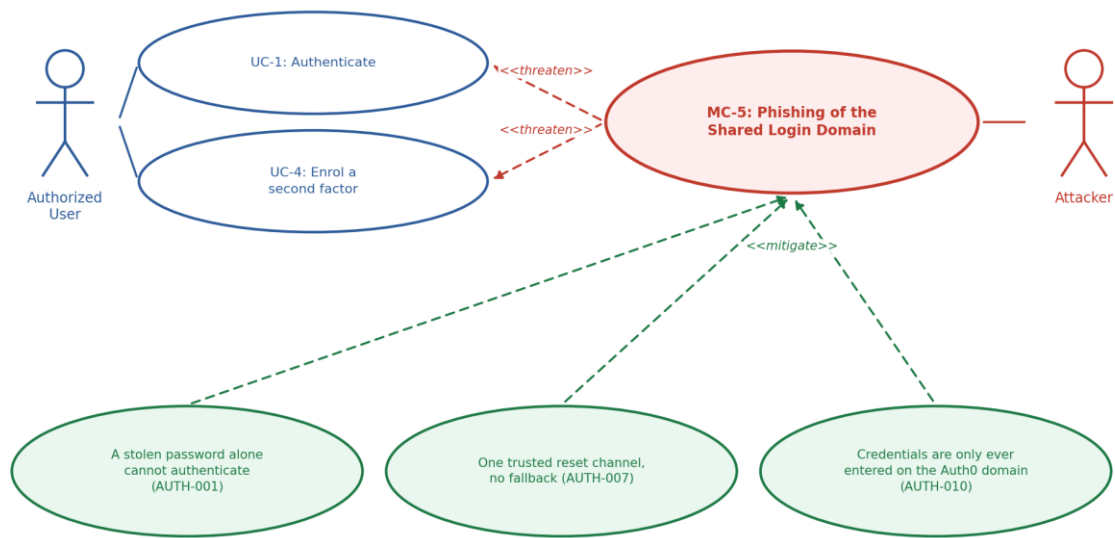


Figure 14: MC-5 phishing of the shared login domain, and the controls that answer it

5.6 Traceability Matrix

This matrix is the security argument of the report in one table: every misuse case is answered by requirements from Section 3, and every requirement traces back to a threat.

Misuse Case	Threatens	STRIDE	Requirements that Mitigate It
MC-1 Brute-force / credential stuffing	UC-1, UC-5, UC-6	Spoofing, Denial of Service	AUTH-001, AUTH-002, AUTH-003, AUTH-004, INPUT-004, INPUT-005, AUDIT-002
MC-2 Broken SSO trust boundary	UC-3, UC-8	Tampering, Elevation of Privilege	INFRA-001, API-002, AUDIT-001
MC-3 Automated bot signup	UC-2	Denial of Service, Spoofing	INPUT-005, AUTH-005, AUTH-004, AUDIT-003
MC-4 Session left open on a shared computer	UC-3, UC-7	Spoofing, Information Disclosure	AUTH-009, AUTH-011, API-003

Misuse Case	Threatens	STRIDE	Requirements that Mitigate It
MC-5 Phishing of the shared login domain	UC-1, UC-4	Spoofing	AUTH-001, AUTH-007, AUTH-010

6. STRIDE Threat Analysis

The table below applies STRIDE to the login and authentication block of AuthGuard: each row states a threat scenario that the system could face, the control that answers it, and the requirement from Section 3 that carries that control. Reading down the Req. column therefore doubles as a coverage check, showing that no category of threat was left without a countermeasure.

STRIDE	Threat Scenario	Mitigation	Req.
Spoofing	An attacker impersonates a user with stolen or reused credentials.	MFA makes a password alone insufficient, and breach screening rejects leaked credentials.	AUTH-001, AUTH-002
Spoofing	An account is taken over using a password exposed in a previous public breach.	Breached Password Detection at signup, login, and reset.	AUTH-002
Spoofing	A cloned login page on a look-alike domain harvests credentials.	MFA means a harvested password alone cannot authenticate.	AUTH-001
Tampering	A portal is misconfigured to a different Auth0 Application, breaking the shared trust chain.	Every portal is registered against one identical tenant and Client ID.	INFRA-001
Tampering	A token is edited to change its claims.	RS256 signature verification with the algorithm pinned; any edit invalidates the signature.	DATA-003, API-002
Repudiation	There is no verifiable record of login attempts or account lockouts, so a user can deny an action.	Every authentication and attack-protection event is logged with user ID, timestamp, IP and outcome.	AUDIT-001, AUDIT-002, AUDIT-003
Information Disclosure	Credentials or tokens are captured in transit on a shared network.	TLS 1.2 or higher on every connection.	DATA-002
Information Disclosure	Error messages reveal which usernames are registered, enabling a targeted attack.	Generic authentication failure messages with uniform timing.	INPUT-004
Information Disclosure	A secret is discovered in the front-end source or repository.	The SPA is a public client with no secret; PKCE replaces it. Secret scanning runs in the pipeline.	DATA-004
Denial of Service	A bot floods the registration or login endpoints with automated requests.	reCAPTCHA v2 on every entry point, per-IP throttling (5 logins, 3 signups), and an account block after 10 failures.	INPUT-005, AUTH-003, AUTH-004
Denial of Service	An attacker deliberately locks a victim out before an exam deadline.	A single trusted self-service reset path, plus administrator unblock, restores access.	AUTH-007
Elevation of Privilege	A broken SSO boundary lets a session bypass the trusted tenant's policy.	Single-tenant enforcement; every portal validates the token issuer and audience.	INFRA-001, API-002
Elevation of Privilege	A student reaches an administrative feature because roles are not enforced.	Role claims in the token, checked on the server.	AUTH-009

7. System Workflow

The three diagrams below show the same flows as Section 4, but from the system's point of view. Each box carries the requirement identifier that governs that step, so the diagrams can be read as a visual index into Section 3.

7.1 Registration Workflow

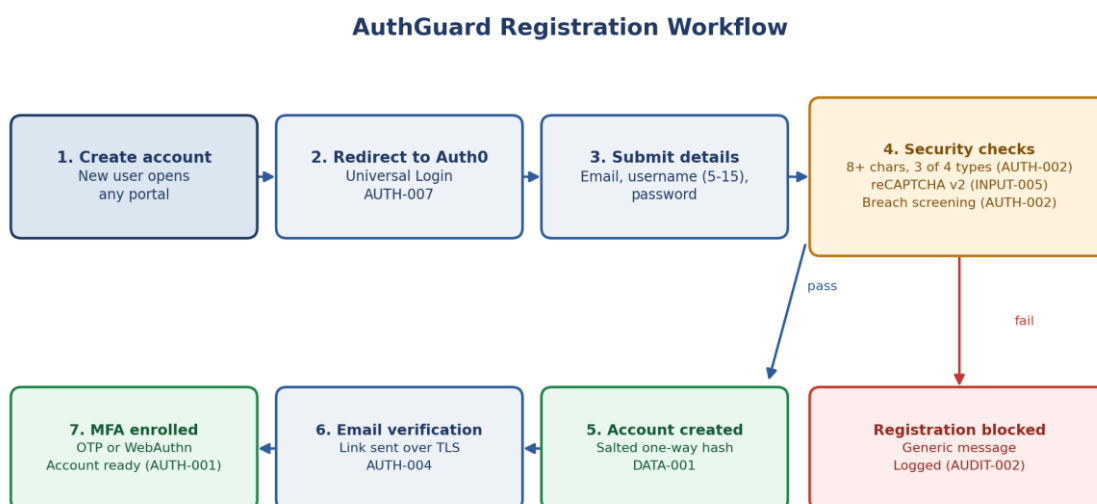


Figure 15: Registration - the three checks that must all pass before an account exists

7.2 Login Workflow

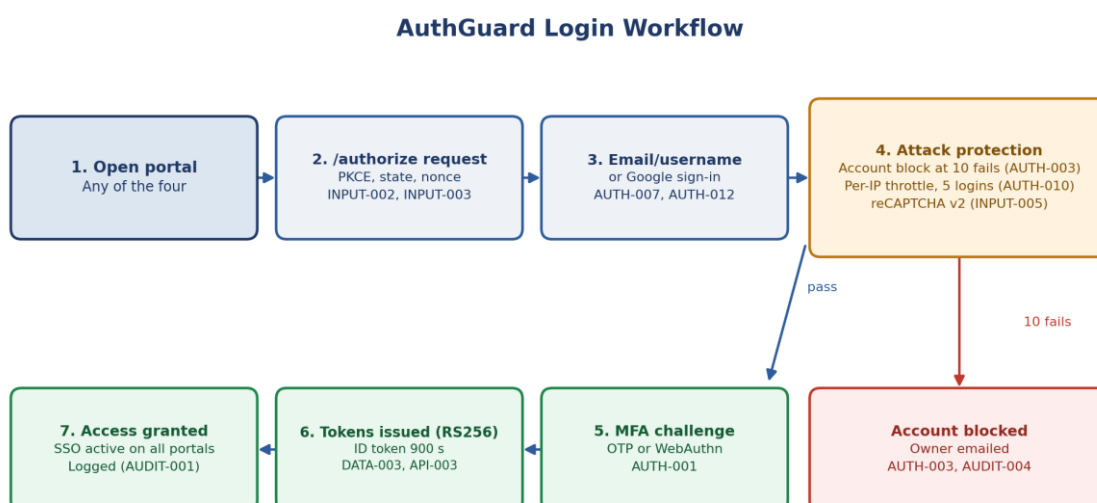


Figure 16: Login - the attack-protection branch and the mandatory MFA step

7.3 SSO and Logout Workflow

The shared session cookie is what makes SSO work, and it is also what makes logout security-relevant: because one cookie serves all four portals, destroying it must end every session at once.

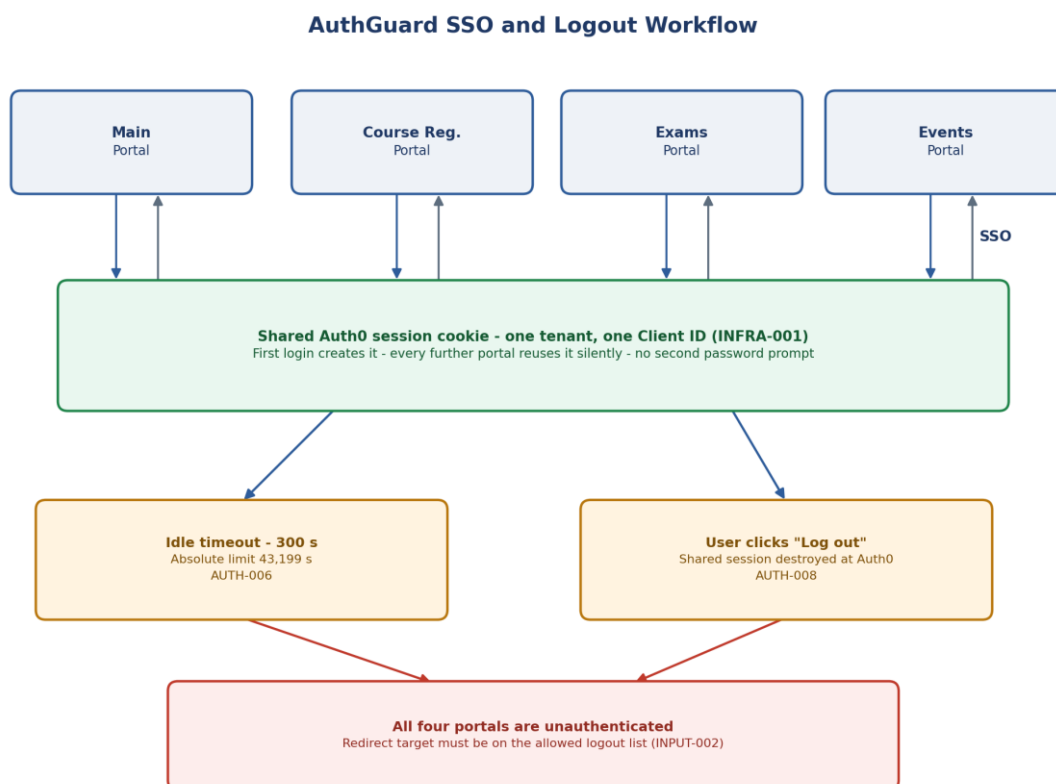


Figure 17: The SSO trust boundary and the two ways a session ends

8. Conclusion

AuthGuard demonstrates a practical, end-to-end secure implementation of the login and authentication block for a distributed, multi-portal system. By integrating Auth0-hosted Universal Login, MFA with OTP and WebAuthn, layered attack protection, and an enforced single-tenant SSO trust boundary, the system mitigates the most common credential-based and identity-boundary threats facing university web platforms.

The security argument rests on traceability rather than assertion: five misuse cases were identified, mapped to all six STRIDE categories, and answered by 34 numbered requirements, each with a priority and a verification method. Section 5.6 shows that no misuse case is left unmitigated and no requirement exists without a threat behind it.

References

National Institute of Standards and Technology (NIST), "Digital Identity Guidelines: Authentication and Lifecycle Management," NIST Special Publication (SP) 800-63B, Jun. 2017. [Online]. Available: <https://pages.nist.gov/800-63-3/sp800-63b.html>

Auth0 by Okta, "Universal Login," Auth0 Docs. [Online]. Available: <https://auth0.com/docs/authenticate/login/auth0-universal-login>

Auth0 by Okta, "Attack Protection," Auth0 Docs. [Online]. Available: <https://auth0.com/docs/secure/attack-protection>

Auth0 by Okta, "@auth0/auth0-react SDK," Auth0 Docs. [Online]. Available: <https://auth0.com/docs/libraries/auth0-react>

OWASP Foundation, "Authentication Cheat Sheet," OWASP Cheat Sheet Series. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

OWASP Foundation, "Application Security Verification Standard (ASVS)," v4.0.3.

D. Hardt, Ed., "The OAuth 2.0 Authorization Framework," RFC 6749, Oct. 2012.

N. Sakimura, J. Bradley, and N. Agarwal, "Proof Key for Code Exchange by OAuth Public Clients," RFC 7636, Sep. 2015.